



TraceMask

Identity firewall for online sign-ups

User Guide

A different you for every website, and proof of who leaked it. Install, connect your mailbox, protect sign-ups, catch leaks and exercise your data rights.

Version	TraceMask 1.2 (with Chrome extension)
Date	11 September 2026
Event	Kalpvrksh 2.0 Mini Hackathon 2026
Problem	P16 — Exposure of Personal Identity Through Routine Online Sign-Ups (Cybersecurity)



CRYPTIC_VRUKSH
SECURE · ROOTED · RESILIENT

Built by
Team Cryptic_Vruksh

Contents

1	What TraceMask does	10	Erasure requests
2	Before you start	11	Reports and exports (PDF)
3	Installing	12	Settings
4	First run: vault and mailbox	13	Browser extension
5	Protecting a sign-up	14	Security and privacy
6	Dashboard and monitoring	15	Hackathon demo script
7	Identities	16	Troubleshooting
8	Leak Center	17	Glossary
9	Exposure Map		

About the screenshots

Screens that show aliases, leaks and inbox activity were captured from a test mailbox. That mailbox uses reserved example domains (`.example` , `.test`), so no real company is shown as leaking data. The risk reports for `dominos.co.in` and `canva.com` are real scans, run live on the team laptop on 11 Sep 2026.

1. What TraceMask does

Every sign-up form asks for your email address. Once you hand it over, the same address becomes a permanent identifier. It can be kept forever, shared with partners, sold, or exposed in a breach, and you can never tell which company let it out. Unsubscribing stops the emails but leaves your data on file.

TraceMask runs on your own computer and fixes this in four steps:

1 • Check before you sign up

A live scan checks the site's certificate, domain age, breach history, trackers, security headers, email spoofing protection and privacy policy. It then recommends a trust tier.

2 • A different you for every site

Each site gets its own real, deliverable alias, e.g. `you+mynttra-k3x9p@gmail.com`. Welcome mails and password resets still reach you.

3 • Proof of who leaked it

Only one company ever had that alias. If anyone else emails it, TraceMask flags the leak within seconds, with evidence from your provider's SPF, DKIM and DMARC checks.

4 • Act on it

Leaked mail is quarantined and you get a PDF evidence report. A formal erasure request, citing the DPDP Act 2023 or GDPR, is one click away.

PROBLEM (FROM P16)	HOW TRACEMASK ANSWERS IT
A real address is a persistent identifier	One unique alias per site, so companies have nothing to link across services
You can't tell who leaked or sold your address	Automatic leak attribution with signed-sender evidence
Unsubscribing doesn't delete stored data	Evidence-backed erasure requests with follow-up tracking
Fake details break account recovery	Aliases are real and deliverable. Protected (T2) aliases are never auto-blocked
Managing many identities is complex	Created automatically, one click per sign-up, all listed in one place
Sites deserve different levels of trust	Trust tiers T0–T3, recommended from the live risk scan plus what the sign-up is for

2. Before you start

YOU NEED	DETAILS
A computer	Windows 10/11 (macOS and Linux also work via <code>start.sh</code>)
Node.js 22.13 or newer	Free from nodejs.org, LTS version. No other libraries: TraceMask has zero third-party packages.
A mailbox with IMAP	Gmail is recommended. Zoho Mail or any IMAP-over-TLS server (port 993) also works.
An app password	For Gmail: turn on 2-Step Verification, then create an App Password (16 characters).
Internet access	For live site scans and mailbox sync

Choosing an alias mode

MODE	EXAMPLE	BEST FOR
Plus-address	<code>you+freshkart-k3x9p@gmail.com</code>	Zero setup with Gmail. A determined spammer can strip the <code>+tag</code> .
Catch-all domain	<code>freshkart-k3x9p@mask.yourdomain.in</code>	Full unlinkability. Needs a domain whose catch-all forwards to your mailbox.

3. Installing

- 1 Get the `tracemask` repository from GitHub: **Code → Download ZIP** (then extract), or `git clone`.
- 2 Double-click `start.bat` (Windows), or run `./start.sh` or `npm start`. There is nothing to install.
- 3 Your browser opens `http://localhost:4390`. Create your master password (chapter 4).

Updating is safe

Your data lives in `tracemask\data`, which is never part of the repository, so `git pull` keeps your vault, aliases and evidence.

Useful commands (from the tracemask folder)

```
npm start           # start the server on http://localhost:4390
npm test            # CI smoke test: syntax, manifest, security probe
npm run check -- myntra.com # live self-check with raw RDAP/HIBP/TLS/DNS data
npm run security     # 32-point security probe (app + extension API)
scripts\self-check.bat # double-click self-check (writes to reports)
```

4. First run: vault and mailbox

4.1 Create your local vault

Choose a master password of at least 10 characters that mixes letters with numbers or symbols. It is never stored anywhere. It derives the key (scrypt, then AES-256-GCM) that encrypts your mailbox password on this computer. **If you forget it, the vault cannot be recovered.**

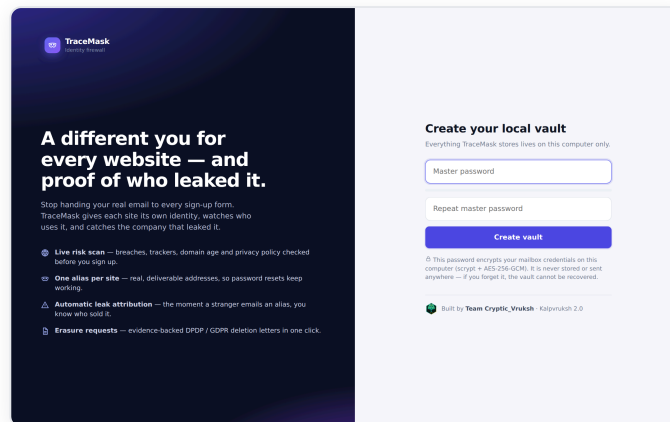


Figure 1 — Creating the local vault (first run).

4.2 Connect your mailbox

- 1 Go to myaccount.google.com → **Security** → **2-Step Verification** and turn it on.
- 2 Open myaccount.google.com/apppasswords, create an app password called “TraceMask”, and copy the 16 characters.
- 3 In TraceMask choose **Gmail**, then enter your Gmail address and the app password.
- 4 Click **Test connection**. TraceMask logs in over TLS and reports your inbox, spam folder and server features.
- 5 Click **Connect & start monitoring**. The first sync reads headers from the last 60 days.

Use the app password, not your Google password

If the browser offers to fill in a saved password here, ignore it. The field accepts only the mailbox app password.

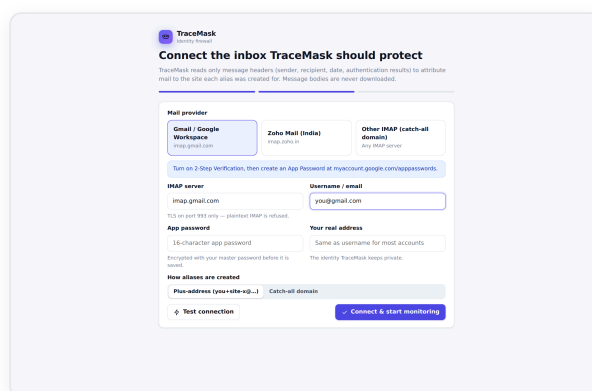


Figure 2 — Connecting Gmail. Only headers are read; message bodies are never downloaded.

5. Protecting a sign-up

- 1 Open **Protect a sign-up** and paste the site address.
- 2 Choose what the sign-up is for: *One-time*, *Regular use*, *Long-term account*, or *Bank / government / KYC*.
- 3 Click **Scan site**. You'll see six live checks complete one by one.
- 4 Read the report and the recommended tier. You can pick a different tier if you prefer.
- 5 Click **Create identity for this site**, then copy the alias into the site's sign-up form.

TraceMask
identity threat

Dashboard
+ Protect a sign-up
MONITOR
Identities
Leak Center
Exposure Map
ACT
Erasure Requests
Site Reports
Settings

Protecting
demo.user@gmail.com
Plus address aliases

Protect a sign-up Synced just now Sync now Lock

Before you sign up, check who you are giving your identity to
TraceMask checks the site live — certificate, domain age, breach history, trackers and privacy policy — then gives you the right identity for it.

dominos.co.in Scan site

What is this sign-up for?

One-time
download, event, free trial, coupon

Regular use
shopping, newsletter, community

Long-term account
email, cloud, work tools I must be able to recover

Bank, government or KYC
regulated services that need verified identity

44
MODERATE RISK

dominos.co.in 44 Moderate
Domino's Pizza - Order Online | Get 2 Regular Pizza @99 Each
Scanned 11 Sept 2026, 06:38 am in 1.0s - 100% of signals verified live

- ✓ **HTTPS certificate** Valid TLSv1.3 certificate from Amazon
- ✓ **Domain age** Registered 21.5 years ago via 101domain GRS Ltd.
- ✗ **Known data breaches** 1 breach on record (latest 2021-03-24, 2,25,27,655 accounts)
- ⚠ **Third-party trackers** 3 trackers on the homepage: Amplitude, Wingify, MoEngage
- ✗ **Privacy policy** No privacy policy link found on the homepage or at /privacy, /privacy-policy
- ⚠ **Security headers** Missing HSTS and CSP
- ✓ **Email spoofing protection** DMARC enforced (p=reject)

Breaches (1)
Source: Have I Been Pwned
Domino's India - 2021-03-24
2,25,27,655 accounts - Email addresses, Names, Phone numbers, Physical addresses

Trackers (3)
3 third-party hosts - list: Disconnect (cached)
Amplitude - Analytics | Wingify - Analytics
MoEngage - EmailAggressive

Privacy policy
No privacy policy found on the site.

Recommended trust tier T1 Tracked
Every sender other than this site will be treated as a leak and quarantined.
Share only: This alias - First name only - Skip optional fields (DOB, gender, phone)

T0 - Burner
Expires automatically. For one-time downloads, events, trials.

RECOMMENDED T1 - Tracked
Unique alias; any third party that mails it is flagged and auto-quarantined.

T2 - Protected
Recovery safe alias; leaks are flagged but mail is never auto-blocked.

T3 - Real identity
Bank, government or KYC — use your real details, keep a record.

Label (optional) — e.g. "dominos.co.in account"

Create identity for this site

Figure 3 — Live risk report for dominos.co.in, captured from a real scan on the team laptop. It shows the 2021 “Domino’s India” breach from Have I Been Pwned, three trackers and no findable privacy policy link.

5.1 How the risk score is calculated

SIGNAL	SOURCE	ADDS POINTS WHEN...
HTTPS certificate	TLS handshake with the site	Invalid/untrusted (+25), expiring in 14 days (+5)
Domain age	RDAP registry lookup	<6 months (+25), <1 year (+18), <3 years (+6), unknown (+5)
Known breaches	Have I Been Pwned catalogue	+15 per breach (max 30), +5 if recent, +5 if passwords leaked
Trackers	Homepage HTML + Disconnect list	+3 per tracker (max 24), +4 if >15 third-party hosts
Privacy policy	Policy page text	Missing (+15), sells/shares data (+8), no deletion (+4), no grievance officer (+5)
Security headers	HTTP response	No HSTS (+3), no CSP (+2)
Email spoofing	DNS DMARC record	No DMARC (+4), monitor-only (+2)

Levels: **0-29 low**, **30-54 moderate**, **55-74 high**, **75+ severe**. A check the site refuses (for example, HTTP 403 to automated requests) is marked *unverified* and adds points instead of being assumed safe. A site is never rated “low” when fewer than 60% of signals could be verified.

5.2 Trust tiers

TIER	USED FOR	BEHAVIOUR
T0 Burner	Downloads, events, trials, coupons	Expires after 24 h (configurable). Mail after expiry is quarantined.
T1 Tracked	Shopping, newsletters, communities	Any sender other than the site is a leak and is quarantined automatically.
T2 Protected	Accounts you must be able to recover	Leaks are flagged, but mail is never auto-blocked, so password resets always arrive.
T3 Real	Bank, government, KYC	Use your real details. TraceMask records the disclosure for your exposure history.

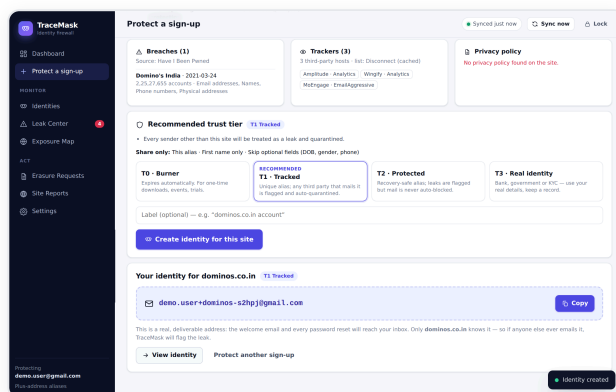


Figure 4 — The new identity. It is a real address, and only this site knows it.

6. Dashboard and monitoring

The dashboard shows open leaks, active aliases, how many organisations still mail your real address, and how much mail was quarantined. The sync pill at the top shows the last sync. **Sync now** runs one immediately.

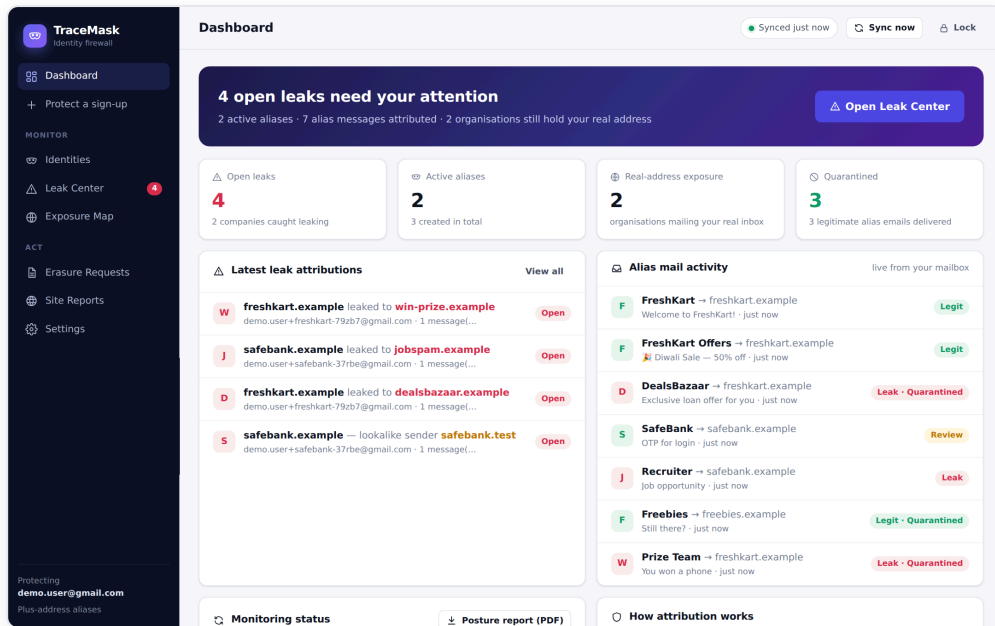


Figure 5 — Dashboard (test mailbox).

- **Real-time:** TraceMask keeps one IMAP IDLE connection open, so new mail is checked within about 2 seconds.
- **Background:** the inbox and spam folders are also re-checked every 2 minutes (configurable), and burner expiry is enforced.
- **Only while unlocked:** monitoring runs only while the vault is unlocked, because the mailbox password stays encrypted otherwise.

7. Identities

Every alias with its site, tier, status, mail count and leak status. Open one to see who has emailed it. You can **block the whole alias** (future mail is quarantined) or **block a single sender**, and keep private notes.

TraceMask

Identity Firewall

Dashboard

Protect a sign-up

Identities

Leak Center

Exposure Map

Erasure Requests

Site Reports

Settings

demo.user+freshkart-79zb7@gmail.com

Plus-address aliases

Identity

Synced just now Sync now Lock

Identities

F

demo.user+freshkart-79zb7@gmail.com

T1 Tracked

Active

Copy

Site report

Erasure request

Block alias

2 leaks attributed to freshkart.example: win-prize.example, dealsbazaar.example

Who has emailed this identity

SENDER	MSGs	FIRST SEEN	VERDICT
freshkart.example	2	11 Sept 2026	Legit Block se
win-prize.example	1	11 Sept 2026	Leak Block se
dealsbazaar.example	1	11 Sept 2026	Leak Block se

Notes

e.g. used for the Diwali sale account

Save note

Messages headers only — bodies are never downloaded

RECEIVED	FROM	SUBJECT	AUTH	VERDICT
11 Sept 2026, 06:40 am	FreshKart updates@freshkart.example	Welcome to FreshKart! Sender domain matches freshkart.example	SPF pass · DKIM pass · DMARC pass	Legit
11 Sept 2026, 06:40 am	FreshKart Offers offers@mail.freshkart.example	🔥 Diwali Sale — 50% off Sender domain matches freshkart.example	SPF pass · DKIM pass · DMARC pass	Legit
11 Sept 2026, 06:40 am	DealsBazaar deals@dealsbazaar.example	Exclusive loan offer for you dealsbazaar.example (authenticated sender) is using ...	SPF pass · DKIM pass · DMARC pass	Identity created

Figure 6 — Identity detail with per-sender verdicts (test mailbox).

8. Leak Center

Each card shows the chain **site the alias was issued to** → **the alias** → **who actually used it**, followed by the evidence.

VERDICT	MEANING
High confidence	The sender passed DKIM/DMARC for its own domain, so a real organisation obtained your alias. That means onward sharing, sale or a breach.
Medium confidence	The sender is unauthenticated. This is typical of spam lists built from breached or traded data, and the alias still left the original site.
Lookalike: review	Same brand name on another domain (e.g. <code>safebank.test</code> vs <code>safebank.example</code>). Confirm it's the same company, or treat it as phishing.

The screenshot displays the TraceMask Leak Center interface. On the left is a sidebar with navigation options: Dashboard, Protect a sign-up, MONITOR (Identities, Leak Center (4), Exposure Map), ACT (Erasure Requests, Site Reports, Settings), and a footer section for 'demo.user@gmail.com'. The main area is titled 'Leak Center' and includes a sync status 'Synced just now' and a 'Sync now' button. It shows three summary cards: 'Open leaks' (4), 'Companies that leaked' (2), and 'Leaked messages caught' (4). Below these are three detailed leak entries:

- Entry 1 (Medium Confidence, Open):** ALIAS ISSUED TO `freshkart.example` → IDENTITY `demo.user+freshkart-79zb7@gmail.com` → USED BY `win-prize.example`. Details include: Alias created 11 Sept 2026, 06:40 am; First leaked mail 11 Sept 2026, 06:40 am — "You won a phone"; Sender Prize Team <winner@win-prize.example>; Authentication SPF softfail · DKIM none · DMARC fail — verified by mx.google.com; Why it is flagged Only freshkart.example was ever given this address. The sender is not authenticated (typical of spam lists built from breached or sold data). Actions: Draft erasure request, Evidence report (PDF), JSON, Open identity, Confirm leak, Not a leak (same company). Status: T1 Tracked.
- Entry 2 (High Confidence, Open):** ALIAS ISSUED TO `safebank.example` → IDENTITY `demo.user+safebank-37rbe@gmail.com` → USED BY `jobspam.example`. Details include: Alias created 11 Sept 2026, 06:40 am; First leaked mail 11 Sept 2026, 06:40 am — "Job opportunity"; Sender Recruiter <hr@jobspam.example>; Authentication SPF pass · DKIM pass (jobspam.example) · DMARC pass — verified by mx.google.com; Why it is flagged Only safebank.example was ever given this address. jobspam.example is an authenticated sender, so this is real onward sharing, sale or breach — not spoofing. Actions: Draft erasure request, Evidence report (PDF), JSON, Open identity, Confirm leak, Not a leak (same company). Status: T2 Protected.
- Entry 3 (High Confidence, Open):** ALIAS ISSUED TO `freshkart.example` → IDENTITY `demo.user+freshkart-79zb7@gmail.com` → USED BY `dealsbazaar.example`. Details include: Alias created 11 Sept 2026, 06:40 am; First leaked mail 11 Sept 2026, 06:40 am — "Exclusive loan offer for you"; Sender DealsBazaar <deals@dealsbazaar.example>. Actions: Draft erasure request, Evidence report (PDF), JSON, Open identity, Confirm leak, Not a leak (same company). Status: T1 Tracked.

Figure 7 — Leak Center (test mailbox with .example domains).

Actions: *Draft erasure request* · *Evidence report (PDF)* · *JSON* (machine-readable evidence with a SHA-256 digest) · *Open identity* · *Confirm leak* · *Not a leak (same company)*. The last one teaches TraceMask that the domain belongs to the site and reclassifies its mail.

9. Exposure Map

Shows every organisation that currently mails your **real** address. It is built from the headers of inbox and spam mail in the look-back window. Individuals (gmail.com, outlook.com and similar) are excluded, and subjects of real-address mail are never stored.

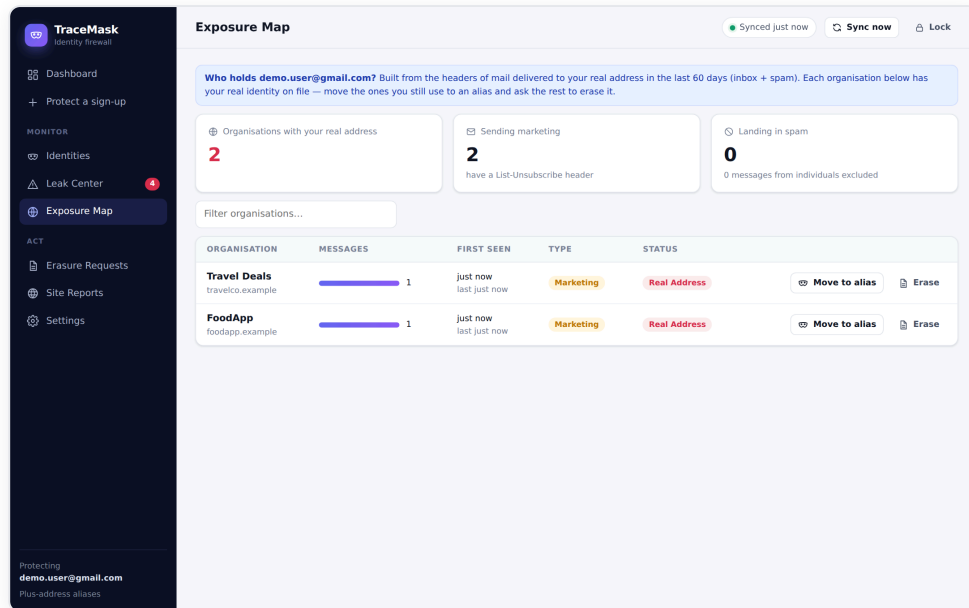


Figure 8 — Exposure Map (test mailbox).

For each organisation: **Move to alias** scans the site and creates an alias, which you then set as your email on that site. **Erase** drafts an erasure request.

10. Erasure requests

- 1 Click **Draft erasure request** on a leak, an identity, or an Exposure Map row.
- 2 Pick the legal basis: **India DPDP Act 2023**, **GDPR Art. 17**, or **policy-based**. TraceMask pre-fills the recipient from the contacts it found in the privacy policy.
- 3 Review the letter, then click **Open in mail app & mark sent**. Send it *from the alias in question* so the company can verify you.
- 4 Track it under **Erasure Requests**: sent → got reply → closed. A follow-up reminder appears after 30 days, and you can download the letter as a PDF.

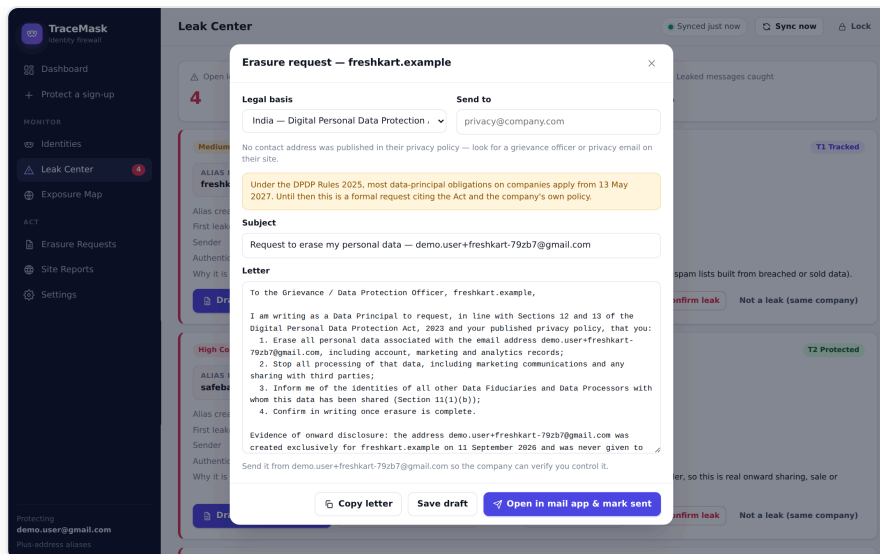


Figure 9 — Evidence-backed DPDP erasure letter.

Honest legal note

Under the DPDP Rules 2025 (notified 13 Nov 2025), most obligations on companies apply from 13 May 2027. Until then the letter is a formal request that cites the Act and the company's own policy. GDPR applies to organisations established in, or targeting, the EU/UK. TraceMask is not legal advice.

11. Reports and exports (PDF)

REPORT	WHERE	CONTENTS
Leak evidence report	Leak Center → Evidence report (PDF)	Report ID, finding, parties, timeline, messages with SPF/DKIM/DMARC, raw header block, per-message SHA-256, evidence digest, method, DPDP ss. 8(5), 8(6), 11, 12 and 13, chain of custody, data-minimisation statement, signature block.
Sign-up risk assessment	Site Reports → site → Risk report (PDF)	Score meter, signal coverage, every factor with evidence, DNS/TLS/RDAP facts, breaches, trackers, policy findings, identities issued, method and limitations.
Privacy posture report	Dashboard or Settings	Key figures, attributed leaks, identities, organisations holding your real address, erasure requests, security audit trail, controls.
Erasure request letter	Erasure Requests → PDF	Formal letter with reference number and an evidence annex (report ID and digest).

Verifying a report

Every leak report prints an **evidence digest** (SHA-256). The JSON export of the same leak contains `evidenceDigest` and the `evidence` object. Recompute SHA-256 over `JSON.stringify(evidence)` and it must match. Header hashes can be recomputed from the original messages still in your mailbox.

TRACEMASK | LEAK ATTRIBUTION EVIDENCE

Evidence that freshkart.example disclosed an identity to dealsbazaar.example

Prepared from message headers retrieved over TLS from the data principal's own mailbox. Intended to support a grievance to the Data Fiduciary and, if unresolved, a complaint to the Data Protection Board of India.

Report ID

Generated

Data Fiduciary

Unauthorised recipient

Identity (alias)

Finding

Evidence digest

TM-LEAK-20260911-0001-56E668E3

11 Sept 2026, 12:12 IST (2026-09-11T06:42:28.479Z UTC)

freshkart.example

dealsbazaar.example

demo.user+freshkart.79zb7@gmail.com

Leak - high confidence

SHA-256 56e668e3a98c60c7990cfa1eb2425524a0dad84619156a2c31c325575cc5939

1. Summary of finding

Onward disclosure detected

The email address demo.user+freshkart.79zb7@gmail.com was generated on 11 Sept 2026, 12:10 IST exclusively for freshkart.example and was not given to any other party. On 11 Sept 2026, 12:10 IST it received email from dealsbazaar.example. The messages passed sender authentication (DKIM/DMARC) for dealsbazaar.example, so they genuinely originate from that organisation; the address could only have reached it through freshkart.example (sharing, sale or a security breach).

2. Parties and identifiers

Data Principal

Data Fiduciary

Purpose of disclosure

Trust tier at sign-up

Recipient of disclosed data

Mail provider (verifier)

Holder of demo.user+freshkart.79zb7@gmail.com (real identity withheld in this report - data minimisation)

freshkart.example

Regular use: shopping, newsletter, community

T1 Tracked

dealsbazaar.example

mx.google.com

3. Timeline

WHEN (IST)

EVENT

11 Sept 2026, 12:10 IST

Unique alias created in TraceMask and used only on freshkart.example

CONFIDENTIAL - contains personal data (DPDP Act 2023)

Generated 11 Sept 2026, 12:12 pm IST | Page 1 of 3

Leak evidence report — page 1

TRACEMASK | PRE-DISCLOSURE RISK ASSESSMENT

Risk assessment: dominos.co.in

Measured live from public sources before personal data is shared: TLS certificate, DNS and email authentication, domain registration (RDAP), breach history (Have I Been Pwned), homepage trackers, security headers and the published privacy policy.

Report ID

Target

Scanned

Risk score

Signal coverage

TM-SITE-20260911-0005-286463E0

https://dominos.co.in/

11 Sept 2026, 12:08 IST (1.0 s)

44/100 - moderate

100% verified live

1. Result

Overall sign-up risk

44/100 MODERATE

SIGNAL

STATUS

FINDING

POINTS

HTTPS certificate

good

Valid TLSv1.3 certificate from Amazon

0

Domain age

good

Registered 21.5 years ago via 101domain GRS Ltd.

0

Known data breaches

bad

1 breach on record (latest 2021-03-24, 2,25,27,655 accounts)

+15

Third-party trackers

warn

3 trackers on the homepage: Amplitude, Wingify, McEngage

+9

Privacy policy

bad

No privacy policy link found on the homepage or at /privacy, /privacy-policy

+15

Security headers

warn

Missing HSTS and CSP

+5

Email spoofing protection

good

DMARC enforced (p=reject)

0

2. Evidence collected

TLS certificate

DNS

DMARC

Registration (RDAP)

Homepage

Security headers

Valid - TLSv1.3, issuer Amazon, expires 05 Feb 2027

18.66.57.47, 18.66.57.70, 18.66.57.125, 18.66.57.100, MX inbound-smtp.us-east-1.amazonaws.com

p=reject v=DMARC1; p=reject; pct=100; rua=mailto:report@dominos.co.in; ru=mailto:forensics@dominos

03 Mar 2005 via 101domain GRS Ltd.; source https://rdap.nixregistry.in/rdap/domain/dominos.co.in

HTTP 200 https://www.dominos.co.in/

none

INTERNAL - privacy risk assessment

Generated 11 Sept 2026, 12:12 pm IST | Page 1 of 2

Risk assessment — real scan of dominos.co.in

12. Settings

SETTING	DEFAULT	WHAT IT DOES
Sync interval	2 min	Background re-check of inbox and spam (IMAP IDLE also triggers instant syncs)
Initial look-back	60 days	How far back the first sync reads headers
Burner lifetime	24 hours	When T0 aliases expire
Alias style	Named	<code>you+site-k3x9p@</code> (easy to recognise) or opaque <code>you+q7m2x9k4pd@</code> (reveals nothing)
Quarantine	On	Moves leaked or blocked mail to the <code>TraceMask-Quarantine</code> folder. It never deletes.
Real-time (IDLE)	On	Keeps one IMAP connection open for near-instant alerts

Settings also shows your mailbox connection, lets you change the master password, and holds recent sync runs, the security audit log, the privacy posture PDF and a JSON export of your data.

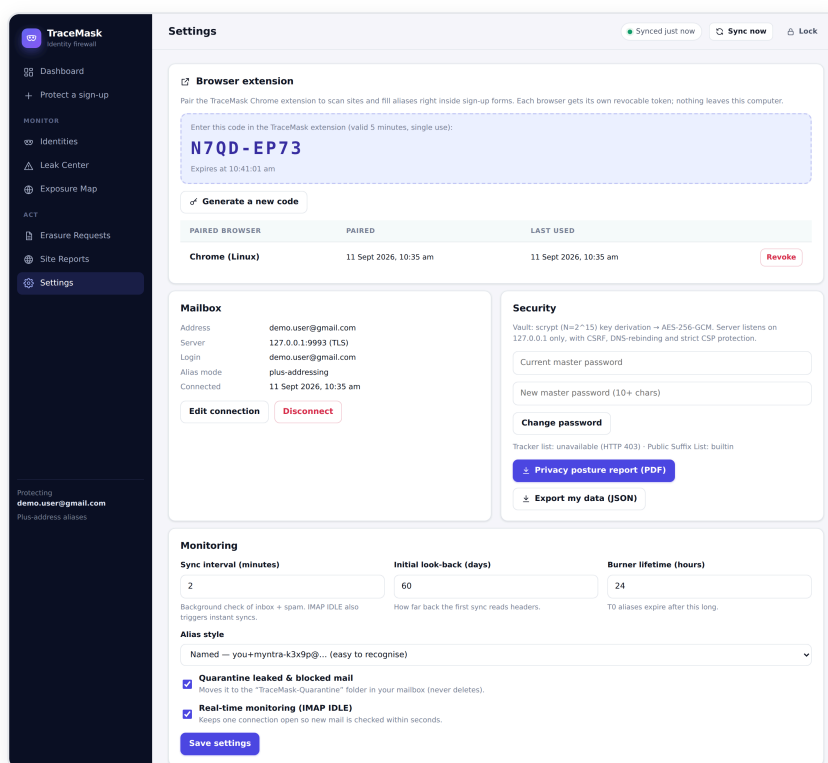


Figure 10 — Settings.

13. Browser extension

The TraceMask extension for Chrome and Edge brings TraceMask into the sign-up form itself. Click the mask button in an email field and it checks the site live, recommends a trust tier, and fills a fresh alias. No copy-paste is needed. The extension talks only to the TraceMask app on your own computer.

13.1 Install (about one minute)

- 1 Start TraceMask (`start.bat` or `npm start`) and unlock it.
- 2 In Chrome, open `chrome://extensions` and turn on **Developer mode** (top right). In Edge, use `edge://extensions` .
- 3 Click **Load unpacked** and select the `extension` folder inside the `tracemask` repository, the one that contains `manifest.json` . The extension's settings page opens.
- 4 Pin it from the puzzle-piece menu so the TraceMask icon stays in the toolbar.

13.2 Pair it with TraceMask

- 1 In TraceMask, open **Settings → Browser extension** and click **Generate pairing code**.
- 2 Type the 8-character code on the extension's settings page and click **Pair with TraceMask**.
- 3 The Connection card turns green and shows the app, vault, mailbox and open leaks.

Why a code?

The code works once, expires after 5 minutes and burns after 5 wrong guesses. The browser then gets its own 256-bit key. TraceMask stores only a hash of it, and you can revoke it from either side at any time.

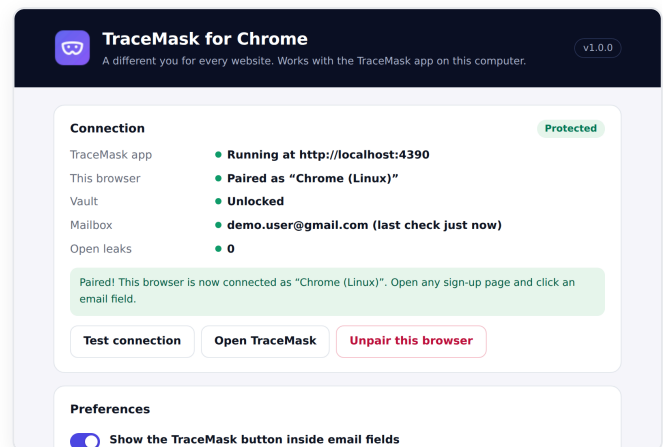


Figure 11 — Extension settings after pairing.

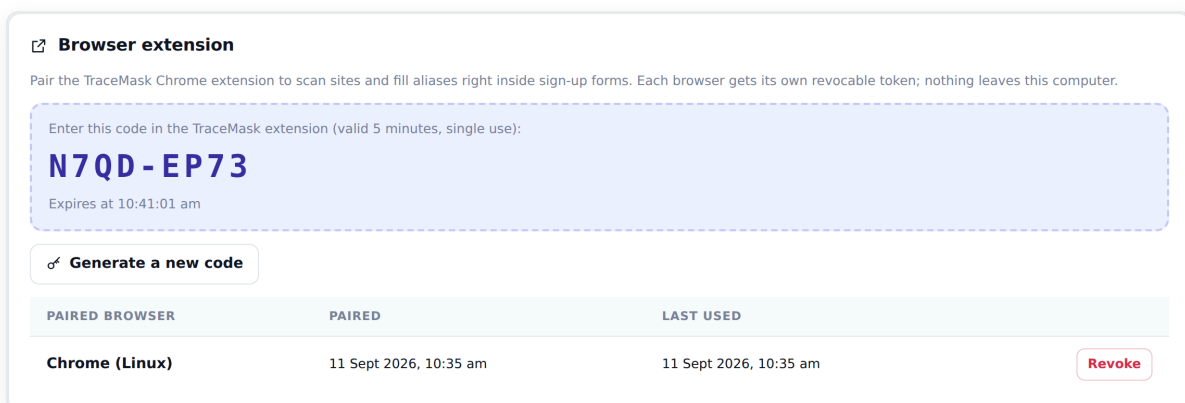


Figure 12 — Settings → Browser extension: one-time code and paired browsers (with Revoke).

13.3 Protecting a sign-up with one click

- 1 Open the site's sign-up page and click the email field. A small mask button appears inside the field.
- 2 Click the button. TraceMask shows the site's live risk score and main issues (from the same scanner as the app).
- 3 Pick what the sign-up is for: *One-time*, *Regular*, *Recoverable* or *Bank/KYC*. The recommended tier updates.
- 4 Click **Create alias & fill**. The alias goes into the email field and any “confirm email” field. The password field is never touched.

Create your account
www.dominos.co.in

Full name

Email address

Confirm email
Re-enter email

Mobile number

Password

TraceMask
dominos.co.in

Moderate Risk
44 Main issues: known data breaches, privacy policy
1 breach on record

What is this sign-up for?

One-time
download, trial

Regular
shop, newsletter

Recoverable
must reset password

Bank / KYC
real identity

Recommended: T1 Tracked. Every sender other than this site will be treated as a leak and quarantined.

Create alias & fill

My identities Leak Center

Figure 13 — The in-page panel: live risk and tier recommendation.

Create your account
www.dominos.co.in

Full name

Email address

Confirm email
Re-enter email

Mobile number

Password

TraceMask
dominos.co.in

Moderate Risk
44 Main issues: known data breaches, privacy policy
1 breach on record

Filled! Only dominos.co.in will ever know this address.

demo.user+dominos-6h7xh@gmail.com

Done **Copy**

My identities Leak Center

Figure 14 — Alias created and filled into the form.

Next time you visit the site, the panel offers the same alias with **Fill this alias**, so each site always gets its own identity.

13.4 Toolbar popup, right-click and shortcut

Click the TraceMask icon to see the current site's risk, your alias for it (**Fill**, **Copy**), a **Scan/Rescan** button and your open leaks. When a leak is caught, the icon shows a red count and Windows shows a notification. Clicking the notification opens the Leak Center.

ALSO	HOW
Right-click menu	Right-click an input → Fill TraceMask alias for this site
Keyboard	Alt+Shift+E fills your alias into the email field you are in (change at <code>chrome://extensions/shortcuts</code>)
Check a page	Right-click the page → Check this site with TraceMask

BADGE	MEANING
1	Open leaks waiting in the Leak Center
LOCK	The vault is locked. Unlock TraceMask with your master password.
OFF	The TraceMask app is not running. Start <code>start.bat</code> .

TraceMask
Protecting demo.user@gmail.com **1 open leak**

D **dominos.co.in**
1 leak from this site

44 **Moderate Risk**
1 breach · 3 trackers · 100% verified

- 1 breach on record (latest 2021-03-24, 2,25,27,655 accounts)
- No privacy policy link found on the homepage or at /privacy, /privacy-policy
- 3 trackers on the homepage: Amplitude, Wingify, MoEngage

Your alias here

demo.user+dominos-6h7xh@gmail.com

T1 Tracked **1 leak** **Fill** **Copy**

Rescan

OPEN LEAKS (1)

- dominos.co.in** leaked to **leadsbroker.example**
demo.user+dominos-6h7xh@gmail.com

Open Leak Center →

Open TraceMask **Settings**

Figure 15 — Popup: site risk, your alias and an open leak.

13.5 How the extension protects you

- Local only.** It connects to `http://localhost:4390` and nowhere else. It has no cloud server, no analytics and no remote favicons.
- Minimal data.** It sends only the address of the page you act on, and only when you click. It never reads or sends page content, passwords or form data.
- Isolated UI.** The panel runs in a closed Shadow DOM, so websites cannot read or restyle it. It works on sites with strict Content-Security-Policy and Trusted Types.
- Least privilege.** Scripts inside web pages can only look up their own site. Pairing, settings and the leak list are limited to the extension's own pages, and the key is not readable from page scripts.
- Tested end to end.** 52 automated browser checks cover pairing, inline fill on a React-style form, the popup, leak alerts through IMAP IDLE, the lock and offline states, revocation, and installing while a sign-up tab is already open.

14. Security and privacy

14.1 Built-in controls

AREA	CONTROL
Secrets	Master password never stored. <code>script</code> ($N=2^{15}$) derives a key that unwraps a random 256-bit data key, and the IMAP password is sealed with AES-256-GCM. Brute-force lockout with growing delays.
Network exposure	Listens on 127.0.0.1 only. Host-header allow-list blocks DNS rebinding. Custom header plus same-origin check on every write blocks CSRF.
Browser	Strict Content-Security-Policy with no inline scripts, frame-ancestors none, nosniff, no-referrer, COOP/CORP. HttpOnly SameSite=Strict session cookie with a 256-bit token. All data is rendered as text, never as HTML.
Mail	IMAP over TLS only (port 993). Headers only, never bodies. Raw headers are kept only for leak evidence, with SHA-256 hashes.
Scanner (SSRF)	Every request and redirect hop must resolve to a public IP. Loopback, private, link-local, CGNAT and cloud-metadata addresses are refused.
Supply chain	Zero third-party npm packages. Only Node.js built-ins are used.
Browser extension	A one-time pairing code (5 minutes, 5 guesses) gives each browser its own 256-bit key, which is stored only as a hash. Cookies never authenticate the extension API and web origins get a 403.

14.2 Vulnerability assessment (11 Sep 2026)

We tested the app against the OWASP Top 10 categories that apply to a local web app. The review found and fixed these issues:

SEVERITY	FINDING	FIX
High	A URL with malformed percent-encoding crashed the server. Any website you visited could trigger this with an image tag pointing at localhost (cross-site DoS).	Safe decoding everywhere; bad requests get a 400
Medium	SSRF: the scanner could be pointed or redirected to internal addresses (router admin pages, 169.254.169.254).	DNS-validated public-IP guard on every redirect hop
Medium	IMAP command injection through CR/LF characters in credentials (LOGIN fallback path).	Control characters rejected; host must be a public DNS name
Medium	The browser could auto-fill the master password into the IMAP app-password field (seen during team testing).	<code>autocomplete="new-password"</code> and distinct field names
Low	Regexes prone to catastrophic backtracking on hostile HTML; unbounded header and IMAP literal sizes.	Linear-time scanners; size caps
Low	The static-file path check used a plain prefix match; dotfiles could be served; TRACE and other methods were accepted; oversized bodies reset the connection.	Separator-aware containment, dotfiles blocked, 405 for other methods, 413 for large bodies

14.3 Automated security probe — results

`npm run security` runs 32 checks against a running instance: 24 for the web app and 8 for the browser-extension API (EXT- *). All of them pass on the current build (v1.2). On the team laptop (Windows 11, Node 24.16) the 17 web checks that don't need a login also passed on v1.1.

ID	CHECK	RESULT
A05-1	Content-Security-Policy blocks inline script & framing	PASS
A05-2	X-Frame-Options DENY (clickjacking)	PASS
A05-3	X-Content-Type-Options nosniff	PASS
A05-4	Referrer-Policy no-referrer	PASS
A05-5	No Server / X-Powered-By banner	PASS
A05-6	API responses not cacheable	PASS
A05-7	TRACE method not served	PASS
A01-1	DNS-rebinding: foreign Host header rejected	PASS
A01-2	API requires an unlocked session	PASS
A01-3	Data export requires session	PASS
A01-4	CSRF: state change without custom header blocked	PASS
A01-5	CSRF: cross-origin Origin blocked	PASS
A01-6	Path traversal outside /public blocked	PASS
A04-1	Malformed percent-encoding does not crash server	PASS
A04-2	Oversized request body rejected	PASS
A04-3	Invalid JSON rejected cleanly	PASS
EXT-1	Extension API requires a paired-browser token	PASS
EXT-2	Forged / revoked extension token rejected	PASS
EXT-3	Web pages cannot call the extension API (Origin check)	PASS
EXT-4	Pairing codes can only be minted from the unlocked app	PASS
EXT-5	CORS: no access granted to web origins	PASS
EXT-6	CORS: extension origin allowed without credentials	PASS
A07-1	Session cookie is HttpOnly + SameSite=Strict	PASS
A07-2	Session token has ≥ 256 bits of entropy	PASS
A03-1	SQL injection in search is inert (parameterised)	PASS
A03-2	IMAP command injection (CRLF in credentials) rejected	PASS
A03-3	Mailbox host must be a public IMAP server (no internal hosts)	PASS
A08-1	Prototype pollution / type confusion in settings ignored	PASS
A10-1	SSRF: scanner refuses loopback / private / metadata targets	PASS
EXT-7	Session cookie does not authenticate the extension API	PASS
EXT-8	Pairing code burns after 5 wrong guesses	PASS
A07-3	Brute-force lockout on master password	PASS

14.4 Known residual risks

- The local SQLite database (aliases, subjects of alias mail, evidence headers) is not encrypted at rest. The mailbox password is. Protect the computer with full-disk encryption (BitLocker).
- The scanner resolves a hostname and then connects, which leaves a small time-of-check/time-of-use window for DNS-rebinding against the scanner itself.
- The lockout counter is held in memory and resets when the app restarts.
- Plus-addressing reveals your base address to anyone who strips the `+tag`. Use catch-all domain mode for full separation.

15. Hackathon demo script (4 minutes)

TIME	SHOW	SAY
0:00–0:30	Exposure Map	“This is how many organisations hold one student's real email today, and which of them are sending marketing or ending up in spam.”
0:30–1:30	Protect → scan a real site	“Before signing up we check the site live: certificate, domain age, breaches, trackers, privacy policy. This one had a breach of 2.25 crore accounts.”
1:30–2:00	Create T1 alias, sign up	“It's a real address, so the welcome mail and password resets arrive. Only this site knows it.”
2:00–2:45	Teammate emails the alias from another domain	“Within seconds TraceMask flags it, names the company that leaked, shows the DKIM/DMARC proof, and quarantines the mail.”
2:45–3:30	Evidence PDF + erasure letter	“A signed, hashed evidence report and a DPDP erasure request in one click.”
3:30–4:00	Chrome extension + security probe, 32/32	“On a real sign-up page one click scans the site and fills a fresh alias. Zero dependencies, encrypted vault, SSRF-guarded scanner, and 32 attack checks that all pass.”

Before the demo

Unlock the vault, run **Sync now** once, keep a teammate ready with a college or work email account, and open the Leak Center in a second tab.

16. Troubleshooting

SYMPTOM	FIX
"Login rejected by the mail server"	Use a Gmail App Password , not your normal password, and make sure 2-Step Verification is on. Check that IMAP is enabled in Gmail settings.
"TraceMask is already running"	A server is already on port 4390. Use it, or close its window and run <code>start.bat</code> again.
"Node.js 22.13 or newer needed"	Install the current LTS from nodejs.org, then run setup again.
Scan says "site answered HTTP 403"	The site blocks automated checks. The signal is marked unverified and adds risk points, which is expected.
"does not resolve in DNS"	Check the internet connection. TraceMask retries with direct DNS queries if the system resolver fails.
No alias mail showing	Click Sync now . Check that the mail arrived in Gmail. The look-back window only covers the first sync.
A legitimate sender is flagged	In the Leak Center, click <i>Not a leak (same company)</i> . The domain is trusted for that site from then on.
Extension says "TraceMask app is not running"	Start <code>start.bat</code> , then click <i>Test connection</i> on the extension's settings page. The badge shows OFF until the app is reachable.
Extension says "no longer paired"	Its key was revoked in Settings. Generate a new pairing code and pair again.
Can't find quarantined mail	Look in the <code>TraceMask-Quarantine</code> label/folder in your mailbox. Nothing is ever deleted.

17. Glossary

TERM	MEANING
Alias	A unique, deliverable email address created for exactly one site
Leak attribution	Naming the organisation that let an alias out, based on who later emails it
SPF / DKIM / DMARC	Email authentication checks your provider records when mail arrives. They prove which domain really sent a message.
RDAP	The modern replacement for WHOIS. Gives a domain's registration date and registrar.
Have I Been Pwned	A public catalogue of verified data breaches
IMAP IDLE	A mail protocol feature that pushes "new message" events instantly
Data Fiduciary / Principal	DPDP Act terms for the organisation processing data, and the person the data is about
SSRF	Server-side request forgery: tricking a server into contacting internal addresses
Pairing code	A one-time 8-character code that links a browser extension to your TraceMask app

Evidence digest

A SHA-256 fingerprint that shows the evidence has not been altered



CRYPTIC_VRUKSH
SECURE · ROOTED · RESILIENT

TraceMask is built by Team Cryptic_Vruksh
for the Kalpvruksh 2.0 Mini Hackathon 2026.